AUDIT PRODUIT SAAS

Modules hors Fournisseurs et achats

FactureFacile Bénin · 10 novembre 2026

Synthèse des constats et recommandations produit issus de la revue du code et des protections visibles dans le dépôt. Le module Fournisseurs et achats est exclu, car il a fait l'objet d'un audit distinct.

Synthèse exécutive

Les autres modules disposent de bonnes bases SaaS : actions financières historisées, import avec aperçu, contrôles d'accès par rôle et par forfait pour certaines fonctionnalités, et messages qui expliquent les limites des simulations et des prévisions.

Les principaux chantiers recommandés sont de vérifier l'application serveur de tous les quotas commerciaux, de sécuriser le parcours d'encaissement en caisse et d'affiner les permissions des équipes. Ces points sont des recommandations d'audit, pas la preuve qu'une faille exploitable a été observée.

Priorités recommandées

1. Vérifier les quotas réellement appliqués côté serveur

- Les forfaits affichent des plafonds de factures, clients et utilisateurs. Les migrations examinées montrent un contrôle serveur de la limite mensuelle de factures, notamment dans les flux récurrents. En revanche, aucun contrôle équivalent des plafonds clients n'a été identifié dans les migrations consultées.

- Vérifier que créations, imports et opérations groupées appliquent les mêmes limites côté base/RPC, y compris si l'interface est contournée. Confirmer également la cohérence entre les quotas configurés, les textes commerciaux et les états d'abonnement.

Références : src/lib/subscription.ts · src/App.tsx · migrations d'abonnement et de facturation.

2. Ajouter un récapitulatif avant encaissement en caisse

- La caisse enregistre facture, paiement et mouvement de stock dans un flux atomique, avec une clé d'idempotence contre les doublons : fondation solide pour éviter les ventes incohérentes.

- L'action « Encaisser et terminer » lance toutefois l'opération sans étape de confirmation récapitulative. Recommandation : afficher client, articles, quantités, taxes, total et mode de paiement avant validation, puis prévoir la clôture et le rapprochement de caisse par période ou opérateur.

Références : src/CashRegisterPage.tsx · supabase/migrations/20261110193000_cash_register_sales.sql.

3. Affiner les permissions d'équipe

- Le rôle membre peut modifier plusieurs données et déclencher des opérations métier. Pour les entreprises avec plusieurs utilisateurs, des permissions distinctes par domaine réduiraient les erreurs et faciliteraient la délégation.

- À envisager : droits séparés pour factures, paiements/rapprochements, remboursements, dépenses, stock et exports, avec contrôles cohérents dans l'interface et dans les règles/RPC de la base.

Points positifs constatés

- Clients et catalogue : import avec aperçu, détection de doublons, archivage, actions groupées et exports. Plusieurs opérations signalent explicitement les échecs partiels.
- Factures et paiements : suivi des factures, rapprochement avant prise en compte d'un paiement, corrections et remboursements conservés dans l'historique.
- Stock : suivi des mouvements, alertes de seuil et protection contre les opérations simultanées. La limite actuelle à un seul dépôt est annoncée dans l'interface.
- Devis et relances : le flux de devis a été traité séparément. Les relances automatiques sont désactivées par défaut et leur activation requiert une action explicite ; l'historique différencie les envois manuels des résultats du prestataire e-mail.
- Factures récurrentes : accès limité aux forfaits payants jusque dans les règles de la base, et pas uniquement par masquage de navigation.

Améliorations produit à planifier

Dépenses

Compléter le suivi par des budgets, des justificatifs mieux reliés au rapprochement et des catégories comptables configurables. Les dépenses sont paginées dans l'interface, mais les besoins d'export et de justification doivent rester adaptés à la croissance des volumes.

Rapports et trésorerie

Les rapports chargent les données par lots et les pages explicitent leurs hypothèses. La trésorerie est une projection indicative : elle ne représente pas un solde bancaire et extrapole certaines dépenses à partir de l'historique. Maintenir cette limite visible et envisager des rapprochements ou imports bancaires si le produit évolue dans cette direction.

Assistant IA

L'interface décrit les données d'entreprise susceptibles d'être transmises et signale les limites d'historique. Avant une diffusion plus large, documenter le fournisseur, les règles de conservation, la confidentialité et les options de contrôle des données.

Préparation IFU / DGI

Le module indique clairement qu'il s'agit de préparation et de simulation, sans vérification officielle ni connexion à la DGI. Préserver cette distinction dans l'interface, les exports et la communication commerciale tant qu'aucune intégration officielle n'est disponible.

Périmètre et limites

Revue statique des principales surfaces applicatives et migrations accessibles dans le dépôt. L'audit a examiné notamment les modules Clients, Produits & Services, Stock, Factures, Paiements, Dépenses, Caisse, Relances, Trésorerie, Rapports, Récurrences, Assistant IA et Préparation DGI.

Cette synthèse ne constitue ni un audit exhaustif de sécurité, ni une validation comptable ou fiscale, ni un test complet de chaque parcours en production. Les contrôles réels doivent être confirmés sur une base de test et avec les rôles/forfaits concernés. Aucune modification ni opération sur la base de production n'a été effectuée dans le cadre de cet audit.

Fichiers principaux consultés : src/App.tsx · src/BusinessModules.tsx · src/CashRegisterPage.tsx · src/OverdueRemindersPage.tsx · src/CashflowPage.tsx · src/ReportPage.tsx · src/DgiPreparationPage.tsx · src/lib/subscription.ts.